

10 Critical Controls

CrowdStrike Solution Mapping

Research Reference Document

ThinkInfosec · thinkinfosec.org · March 2026

Prepared by Andre Camillo

Sources

NCSC Critical Controls — <https://www.ncsc.govt.nz/protect-your-organisation/summary/>
Individual control detail pages — <https://www.ncsc.govt.nz/protect-your-organisation/>
CrowdStrike Technology Domain Mapping (ThinkInfosec reference)

Coverage Rating Legend

Rating	Meaning
STRONG	CrowdStrike provides primary or substantial native coverage for this control
DETECT / PRIORITISE	CrowdStrike surfaces and prioritises the problem; remediation tooling still required
PARTIAL	CrowdStrike covers detection and early-warning aspects but core capability gap exists
DETECT ONLY	Detection-layer coverage; separate infrastructure or tooling required for enforcement
MINIMAL	Near-full gap; CrowdStrike provides limited compensating detective value only

All 10 Controls at a Glance

#	NCSC Critical Control	Primary CrowdStrike Products	Coverage Rating
01	Patch Your Software and Systems	Exposure Management	DETECT / PRIORITISE
02	Implement Multi-Factor Authentication and Verification	FalconID (GA February 2026), Falcon Identity Protection (Next Gen Identity), NG-SIEM, Counter Adversary Operations	STRONG — NATIVE FIDO2 MFA + DETECT
03	Provide and Use a Password Manager	Falcon Identity Protection (Next Gen Identity), Counter Adversary Operations	MINIMAL — DETECTIVE ONLY
04	Centralised Logging	NG-SIEM (Next Generation SIEM), Falcon Insight XDR (EDR), Falcon Identity Protection	STRONG
05	Build Security Awareness in Your Organisation	Counter Adversary Operations (Threat Intelligence), Falcon Complete MDR	MINIMAL — INTEL INPUT ONLY
06	Asset Lifecycle Management	Exposure Management, Cloud Security (CSPM)	STRONG
07	Implement and Test Backups	Falcon Insight XDR (EDR) / Falcon Prevent, NG-SIEM	PARTIAL — DETECTION ONLY
08	Implement Application Control	Falcon Prevent (Next-Gen Antivirus), Falcon Insight XDR (EDR), Exposure Management, Falcon Fusion (SOAR)	STRONG (behavioural) / PARTIAL (strict allowlisting)
09	Enforce the Principle of Least Privilege	Falcon Identity Protection (Next Gen Identity), Falcon Privileged Access (FPA), Cloud Security CNAPP, Exposure Management	STRONG — DETECT + ENFORCE + JIT
10	Implement Network Segmentation and Separation	Falcon Insight XDR (EDR) + NG-SIEM, Falcon XIoT, Cloud Security CNAPP	DETECT ONLY — INFRA GAP

CONTROL 01

Patch Your Software and Systems

Coverage: **DETECT / PRIORITISE** · <https://www.ncsc.govt.nz/protect-your-organisation/patching/>

NCSC Intent

Ensure all software — OS, applications, firmware, IoT — is kept current. Timely patching is NCSC's single most-cited control; unpatched vulnerabilities remain the top attack vector seen in their incident data.

Key Requirements

- Maintain a full inventory of software/firmware (CMDB or discovery tooling)
- Subscribe to vendor patch feeds; track CVEs via NIST NVD RSS
- Define patch SLAs: emergency (24–72 hr), critical (7 days), routine (30 days)
- Automate download, staging, testing, and deployment where possible
- Document and risk-accept any delayed/cancelled patches
- Cover IoT and legacy systems explicitly; compensating controls for EOL kit

Measure of Success

Complete software inventory; all systems current; mostly automated pipeline; patch exceptions tracked and risk-owned.

CrowdStrike Solution Mapping

CrowdStrike Product / Module	How It Addresses This Control
Exposure Management — Falcon Spotlight	Continuous vulnerability scanning across all managed endpoints; maps CVEs to affected hosts; prioritises by exploitability and asset criticality. Directly addresses NCSC's requirement for scanning and patch verification.
Exposure Management — Falcon Discover	Real-time asset inventory (hardware, software, unmanaged devices). Satisfies CMDB accuracy requirement; detects shadow IT and legacy systems that fall outside normal patch cycles.
Exposure Management — Falcon Surface (EASM)	External attack surface view; identifies internet-facing assets that may be running unpatched services visible to attackers before defenders notice.
Exposure Management — CTEM	Aggregates VM, CMDB, and threat intel data into prioritised remediation workflows. Bridges the gap between 'knowing you're unpatched' and 'knowing what to fix first'.

Gaps & Limitations

CrowdStrike surfaces what needs patching and validates post-remediation — it does not deliver patches. Organisations still need a patching tool (e.g., WSUS, Intune, Ansible). Falcon Spotlight coverage requires the Falcon sensor to be deployed; coverage of OT/IoT/legacy devices depends on Falcon XioT or network scanning integrations.

CONTROL 02

Implement Multi-Factor Authentication and Verification

Coverage: **STRONG — NATIVE FIDO2 MFA + DETECT** · <https://www.ncsc.govt.nz/protect-your-organisation/multi-factor-authentication-and-verification/>

NCSC Intent

Enforce MFA on all internet-facing accounts, admin accounts, and critical systems. Extends to business process verification — out-of-band checks on payment and credential change requests — to counter BEC and invoice fraud.

Key Requirements

- Identify high-risk systems: VPN, webmail, financial platforms, cloud admin, code repos
- Prefer phishing-resistant methods: FIDO2/U2F (YubiKey), push-notification apps
- Avoid SMS OTP where possible — acceptable only if no better option exists
- Train users to report unsolicited MFA challenges (MFA fatigue attacks)
- Configure centralised auth logs; alert on unusual location and failed MFA patterns
- Implement out-of-band business process verification for payments and access changes

Measure of Success

All internet-facing and admin systems require MFA; auth logs centralised; MFA fatigue attack training completed; verification processes tested.

CrowdStrike Solution Mapping

CrowdStrike Product / Module	How It Addresses This Control
FalconID (GA February 2026)	CrowdStrike's native phishing-resistant MFA — directly aligned to NCSC's top-tier recommendation. FalconID is FIDO2-based biometric authentication delivered through the Falcon for Mobile app. It eliminates passwords, push notifications, and OTPs entirely. Authentication is device-bound (Bluetooth proximity check validates physical presence near the login device, structurally blocking remote MFA fatigue attacks) and domain-bound (authentication tied to legitimate domains so fake login pages cannot intercept credentials). Unlike traditional MFA tools that make a binary pass/fail decision at login, FalconID evaluates real-time Falcon platform risk signals — identity, endpoint, device posture, and adversary intelligence — and can revoke or reduce access mid-session if risk changes. Delivered natively through the Falcon platform with no third-party IdP required for the MFA mechanism itself.
Falcon Identity Protection (Next Gen Identity)	Detection and enforcement layer for identity-based attacks: credential stuffing, password spraying, pass-the-hash, pass-the-ticket, Kerberoasting, MFA fatigue patterns, and impossible travel logins. Enforces conditional access policies and can trigger step-up authentication or block access based on risk score — operating across existing AD, Azure AD, and hybrid environments regardless of which MFA mechanism is in use.
NG-SIEM	Centralises authentication logs from AD, Azure AD, cloud apps, and VPN gateways. Enables correlation rules and alerting on failed MFA attempts, bypass attempts, and unusual login geography — supporting NCSC's monitoring and centralised logging requirements for this control.
Counter Adversary Operations	Threat intelligence on adversary credential theft and MFA bypass techniques (e.g., Scattered Spider's social engineering campaigns). Contextualises identity threats with actor TTPs to inform policy hardening and user awareness.

Gaps & Limitations

FalconID closes the long-standing gap where CrowdStrike had no native MFA delivery mechanism and relied entirely on an external IdP. For organisations with an existing IdP (Entra ID, Okta, Ping), FalconID operates as an additional or replacement authentication layer — adoption will depend on deployment scope and licencing. Business process verification (out-of-band confirmation for payment changes, credential resets) remains entirely outside CrowdStrike's scope and requires organisational process design.

CONTROL 03

Provide and Use a Password Manager

Coverage: **MINIMAL — DETECTIVE ONLY** · <https://www.ncsc.govt.nz/protect-your-organisation/password-managers/>

NCSC Intent

Equip staff with a sanctioned password manager so every account gets a long, unique, randomly generated credential. Reduces credential reuse, simplifies shared-account management, and shrinks the blast radius of phishing.

Key Requirements

- Procure and provision an enterprise password manager (e.g., 1Password, Bitwarden, Keeper)
- Enforce use through policy and ideally technical controls
- Train staff on generating and using strong, unique passphrases
- Manage shared credentials (social media, service accounts) through vault
- Integrate with SSO/IdP where possible for seamless employee experience

Measure of Success

All staff have access to and actively use the password manager; no passwords reused across systems; shared accounts managed in vault.

CrowdStrike Solution Mapping

CrowdStrike Product / Module	How It Addresses This Control
Falcon Identity Protection (Next Gen Identity)	Detects use of compromised credentials (cross-referenced against threat intel) and weak or shared passwords across Active Directory. Provides compensating visibility when password hygiene is poor — effectively alerting when the problem this control is meant to prevent has already occurred.
Counter Adversary Operations — Recon / Overwatch Identity	Dark web monitoring for credential exposure. If employee credentials appear in breach dumps — precisely what poor password hygiene enables — this provides early warning before attackers act on them.

Gaps & Limitations

CrowdStrike does not provide a password manager. This is a FULL GAP for the primary tool requirement. The products listed above are detective compensating controls, not the preventive tooling NCSC recommends. Organisations must source a separate enterprise password manager.

CONTROL 04

Centralised Logging

Coverage: **STRONG** · <https://www.ncsc.govt.nz/protect-your-organisation/centralised-logging/>

NCSC Intent

Aggregate all security-relevant logs (endpoints, auth, network, cloud) into a tamper-protected central system. NCSC notes that lack of logs is a recurring problem in incident investigations — without them, scope and root cause remain unknown.

Key Requirements

- Define a log inventory: business-critical systems, auth failures, legacy protocol usage, physical access
- Send all logs to a hardened central system with RBAC (read-only for analysts)
- Normalise timestamps across all sources (UTC)
- Retain logs long enough for investigation — NCSC notes incidents are often discovered months later

- Set up automated alerting on high-priority events (admin auth failures, config changes)
- Build dashboards for anomaly detection (traffic spikes, blocked URLs)

Measure of Success

All critical sources logging centrally; tamper-evident storage; automated alerting configured; sufficient retention for investigation scope.

CrowdStrike Solution Mapping

CrowdStrike Product / Module	How It Addresses This Control
NG-SIEM (Next Generation SIEM)	CrowdStrike's primary response to this control. Ingests telemetry from Falcon endpoints, identity, cloud, and third-party sources. Provides correlation rules, detection dashboards, and alerting. Cloud-native, petabyte-scale log platform that replaces or augments traditional SIEMs. Directly maps to NCSC's requirement for a central logging system with alerting.
Falcon Insight XDR (EDR)	Provides rich, continuous endpoint telemetry — process trees, network connections, file writes, registry changes — that feeds into NG-SIEM. Each endpoint becomes a high-fidelity log source without manual log configuration.
Falcon Identity Protection	Authentication event logs (AD, Azure AD, LDAP) are captured and enriched with risk scoring before being forwarded to NG-SIEM, supporting NCSC's requirement to log and alert on authentication failures.

Gaps & Limitations

NG-SIEM requires connectors for non-CrowdStrike sources (firewalls, SaaS apps, network devices). These connectors exist but require configuration effort. Log retention duration is a commercial and licencing consideration that must be aligned to NCSC's investigation-ready requirements. NG-SIEM does not cover physical access control systems (swipe card logs) referenced by NCSC.

CONTROL 05

Build Security Awareness in Your Organisation

Coverage: **MINIMAL — INTEL INPUT ONLY** · <https://www.ncsc.govt.nz/protect-your-organisation/build-security-awareness-in-your-organisation/>

NCSC Intent

Invest in ongoing human-layer security. NCSC reports that a significant percentage of breaches involve a human element. Phishing, credential theft, and social engineering depend on exploiting human behaviour, making technical controls alone insufficient.

Key Requirements

- Regular, recurring security awareness training — not just annual compliance checkbox
- Simulated phishing exercises to test and reinforce awareness
- Tailored content for different roles (finance, IT admin, general staff)
- Clear reporting mechanism for suspicious emails and calls
- Culture of security: people feel safe reporting mistakes without fear of blame

Measure of Success

Measurable reduction in phishing simulation click rates; staff actively report suspicious activity; security culture embedded in onboarding.

CrowdStrike Solution Mapping

CrowdStrike Product / Module	How It Addresses This Control
Counter Adversary Operations (Threat Intelligence)	Provides current, contextual threat intelligence on active campaigns targeting NZ/AU organisations and specific industries. Feeds security awareness content with real, relevant examples rather than generic training scenarios — making awareness programmes more compelling and accurate.
Falcon Complete MDR — Threat Intelligence Briefings	Regular threat briefings available via Falcon Complete and Overwatch can be translated into security awareness content relevant to your industry and region.

Gaps & Limitations

CrowdStrike does not provide a security awareness training platform or phishing simulation tool. This is a FULL GAP for the primary requirement. Organisations need a dedicated platform (e.g., KnowBe4, Proofpoint Security Awareness, Cofense). The CrowdStrike value here is enriching training content with real threat intelligence — not delivering the training itself.

CONTROL 06

Asset Lifecycle Management

Coverage: **STRONG** · <https://www.ncsc.govt.nz/protect-your-organisation/asset-lifecycle-management/>

NCSC Intent

Track all hardware and software through their full lifecycle: procurement, deployment, maintenance, and decommissioning. NCSC has seen many incidents caused by forgotten systems — left unpatched, hardened at deployment but never maintained, or running past end-of-support.

Key Requirements

- Maintain an accurate, automated asset inventory (not manually-maintained spreadsheets)
- Track software versions and patch levels per asset
- Monitor vendor support status; flag assets approaching EOL
- Define decommissioning procedures (data wiping, credential and certificate revocation)
- Ensure CMDB accuracy via automated discovery, not manual entry alone

Measure of Success

Real-time, automated inventory of all hardware and software; EOL systems identified and risk-owned; decommissioned assets properly sanitised.

CrowdStrike Solution Mapping

CrowdStrike Product / Module	How It Addresses This Control
Exposure Management —	Real-time, automated asset inventory drawn from Falcon sensors.

CrowdStrike Product / Module	How It Addresses This Control
Falcon Discover	Tracks managed assets, unmanaged devices on the network, cloud workloads, and SaaS accounts. Replaces the out-of-date spreadsheet CMDB anti-pattern. Continuously updated without manual input.
Exposure Management — Falcon Spotlight	Cross-references the asset inventory with vulnerability data to flag assets running EOL software or operating systems with no available patches — directly supporting NCSC's EOL tracking requirement.
Exposure Management — Falcon Surface (EASM)	Discovers externally exposed assets that may have been forgotten — shadow IT or retired systems left internet-facing. Specifically addresses NCSC's concern about systems left undecommissioned.
Cloud Security (CSPM)	For cloud-based assets, continuously inventories cloud resources and flags orphaned or unmanaged workloads that represent lifecycle management failures.

Gaps & Limitations

Falcon Discover provides strong coverage for systems where the Falcon sensor is deployed. Coverage of unmanaged endpoints, OT/ICS systems, and network infrastructure devices is more limited. Full CMDB integration (feeding Falcon data into a ServiceNow or JIRA-style CMDB) requires additional configuration. Physical hardware lifecycle tracking (asset tagging, procurement records) is outside CrowdStrike's scope.

CONTROL 07

Implement and Test Backups

Coverage: **PARTIAL — DETECTION ONLY** · <https://www.ncsc.govt.nz/protect-your-organisation/implement-and-test-backups/>

NCSC Intent

Ensure business-critical data can be restored quickly after a cyber incident (particularly ransomware) or accidental loss. NCSC highlights that ransomware appears consistently in quarterly reports — tested backups are the most cost-effective resilience control.

Key Requirements

- Identify and prioritise critical data for backup
- Follow 3-2-1 rule: 3 copies, 2 different media types, 1 offsite or air-gapped
- Ensure backups are immutable and protected from ransomware encryption
- Test restoration regularly — backups that have not been tested are not backups
- Document RTO/RPO for critical systems and align with business expectations
- Protect backup infrastructure credentials (a common ransomware pivot target)

Measure of Success

Tested, air-gapped, immutable backups in place for all critical systems; RTO/RPO defined and validated; backup credentials protected.

CrowdStrike Solution Mapping

CrowdStrike Product / Module	How It Addresses This Control
Falcon Insight XDR (EDR) / Falcon Prevent	Detects ransomware behaviour — mass file encryption, shadow copy deletion, backup service tampering — before encryption is complete. Early detection reduces the scope of data loss and reduces the likelihood of needing a full restoration. This is not a backup solution; it reduces the frequency with which backups need to be invoked by stopping attacks earlier in the kill chain.
NG-SIEM	Alerting on Volume Shadow Copy Service (VSS) deletion commands, backup service tampering, and unusual access to backup infrastructure paths — providing early warning of ransomware pre-staging before encryption begins. This supports NCSC's monitoring requirement but does not replace backup tooling or backup testing.

Gaps & Limitations

CrowdStrike does not provide backup infrastructure, backup testing, or data recovery capabilities. This is a FULL GAP for the core requirement. The control specifically calls for tested, immutable, air-gapped backups with validated RTO/RPO — none of which CrowdStrike delivers. Organisations need dedicated solutions (e.g., Veeam, Commvault, Azure Backup, AWS Backup). Falcon Complete MDR, while excellent at threat detection and response, does not assist with backup testing or recovery validation either — that scope sits firmly with backup vendors and the organisation's own IT operations team.

CONTROL 08

Implement Application Control

Coverage: **STRONG (behavioural) / PARTIAL (strict allowlisting)** · <https://www.ncsc.govt.nz/protect-your-organisation/application-control/>

NCSC Intent

Prevent unauthorised or malicious software from running. NCSC describes this as one of the most effective controls against malware and ransomware — ranging from full allowlisting (only approved hashes/signatures can execute) to EDR-based behavioural blocking as a lower-effort starting point.

Key Requirements

- Use EDR-based behavioural blocking as minimum viable control
- For higher assurance: implement application allowlisting with hash or publisher-based rules
- Run in audit mode first; move to enforce mode after validation
- Block high-risk file types (macros, script files, executable downloads from internet)
- Monitor for LOLBin (living-off-the-land binary) bypass techniques
- Review policies at least annually; automate rule updates via vendor feeds

Measure of Success

All endpoints have enforced application control; blocked execution attempts logged centrally; policies auto-updated; bypass techniques monitored.

CrowdStrike Solution Mapping

CrowdStrike Product / Module	How It Addresses This Control
Falcon Prevent (Next-Gen)	Machine learning-based prevention that blocks known and unknown

CrowdStrike Product / Module	How It Addresses This Control
Antivirus)	malware without relying solely on signatures. Provides script control (blocks malicious PowerShell, WScript, CScript), macro protection, and suspicious process blocking — effectively implementing behavioural application control.
Falcon Insight XDR (EDR)	Records all process executions, parent-child relationships, and lateral movement. Enables both real-time blocking and retrospective investigation of execution chains. Supports NCSC's requirement to log all blocked execution attempts centrally.
Exposure Management — Falcon Discover (via Falcon for IT)	Provides a full software and package inventory across all managed endpoints — surfaced in the Falcon Exposure Management console. This gives security teams the baseline they need to know what is installed before they can control what is allowed to run. CrowdStrike demonstrated this exact workflow in their OpenClaw blog (Feb 2026): Falcon for IT inventories software packages via agent-based inspection, findings appear centrally in Exposure Management, and NG-SIEM's AI Service Usage Monitor dashboard provides real-time visibility of application activity. This directly supports the 'understand your environment before you enforce' approach NCSC recommends.
Falcon Fusion (SOAR)	Automates response workflows for application control violations — auto-isolating an endpoint when a blocked execution attempt matches a known threat pattern, rather than waiting for analyst review.

Gaps & Limitations

Falcon Prevent is behaviour-based blocking, not traditional allowlisting (which requires explicit hash or signature approval for every permitted application). NCSC acknowledges the behavioural approach as a valid lower-effort option. Organisations requiring strict allowlisting (e.g., government and critical infrastructure) may need a dedicated tool (AppLocker, WDAC, or third-party). LOLBin monitoring requires ongoing rule tuning as bypass techniques evolve.

CONTROL 09

Enforce the Principle of Least Privilege

Coverage: **STRONG — DETECT + ENFORCE + JIT**

<https://www.ncsc.govt.nz/protect-your-organisation/principle-of-least-privilege/>

NCSC Intent

Grant users and processes only the minimum access needed to perform their job. Limits lateral movement if credentials are compromised; reduces blast radius of insider threats and misconfigurations. Requires separate accounts for standard and administrative use.

Key Requirements

- Audit and right-size all user, service account, and cloud entitlements
- Enforce separation of standard and privileged accounts
- Remove standing admin access — use JIT (Just-In-Time) elevated access
- Implement stronger logging and MFA requirements specifically for privileged accounts
- Regularly review and revoke unused access (joiners, movers, leavers process)
- For cloud: audit IAM policies, service principal permissions, and cross-account trust relationships

Measure of Success

No standing admin privileges; all entitlements reviewed on defined cycle; privileged account activity fully logged; cloud IAM follows least-privilege policies.

CrowdStrike Solution Mapping

CrowdStrike Product / Module	How It Addresses This Control
Falcon Identity Protection (Next Gen Identity)	Core detection response to this control. Identifies privilege escalation attacks, unauthorised admin access, Kerberoasting, Golden/Silver Ticket attacks, and pass-the-hash in real time. Enforces risk-based conditional access — blocking or requiring step-up MFA when privilege anomalies are detected. Covers AD, Azure AD, and hybrid environments.
Falcon Privileged Access (FPA)	GA'd April 2025 as a module within Falcon Identity Protection, this is CrowdStrike's native PAM-equivalent. Implements risk-based Just-in-Time (JIT) access — privileges are granted only when needed, within validated risk thresholds, and auto-revoked when conditions change. Eliminates standing admin privileges across on-premises AD and cloud identity providers including Entra ID, without requiring infrastructure changes or separate access portals. Directly addresses NCSC's JIT requirement and the 'no standing admin access' goal.
Cloud Security CNAPP — CIEM + CSPM	CIEM (Cloud Identity & Entitlement Management) analyses and remediates over-permissioned cloud identities — human and machine — identifying unused permissions, excessive IAM roles, and risky cross-account trusts. CSPM continuously flags IAM misconfigurations and overly permissive cloud policies. Together these address NCSC's cloud least-privilege requirements within a single CNAPP workflow.
Exposure Management — Falcon Discover	Identifies shadow admin accounts, local administrator accounts across the entire fleet, and unmanaged privileged access paths that would otherwise be invisible — providing the discovery foundation required before least privilege can be enforced.

Gaps & Limitations

With the GA of Falcon Privileged Access, CrowdStrike now covers JIT natively — which closes a gap that previously required a separate PAM tool. The remaining gap is full entitlement governance: right-sizing entitlements across enterprise applications and SaaS platforms at scale still benefits from dedicated identity governance tooling (e.g., SailPoint, Saviynt). CrowdStrike detects, blocks, and enforces at the identity layer, but does not manage the full joiner/mover/leaver provisioning lifecycle.

CONTROL 10

Implement Network Segmentation and Separation

Coverage: **DETECT ONLY — INFRA GAP** · <https://www.ncsc.govt.nz/protect-your-organisation/network-separation-and-segmentation/>

NCSC Intent

Break the network into smaller zones with access controls between them. Limits lateral movement once an attacker gains initial access. Critical for protecting high-value assets — OT, financial systems, PII stores — from compromise spreading from lower-security segments.

Key Requirements

- Identify critical data and systems; place them in tighter network segments
- Define and enforce inter-segment access rules (default-deny between segments)
- Monitor east-west traffic between segments for anomalous movement
- Segment OT/ICS networks from corporate IT
- Log and alert on inter-segment traffic policy violations
- Regularly review segmentation design as the network evolves

Measure of Success

Critical systems in protected segments; default-deny policy between zones; lateral movement detectable via alerts; OT/IT separation enforced.

CrowdStrike Solution Mapping

CrowdStrike Product / Module	How It Addresses This Control
Falcon Insight XDR (EDR) + NG-SIEM	While CrowdStrike does not configure network segments, it provides the detection layer: lateral movement techniques — SMB scanning, RDP brute force, credential relay attacks, WMI/PsExec-based movement — are detected at the endpoint level regardless of network topology. This partially compensates for inadequate segmentation.
Falcon XIoT	OT/ICS/IoT device visibility and monitoring — critical for NCSC's requirement to segment operational technology networks from corporate IT. Provides asset inventory and anomaly detection for otherwise invisible OT assets.
Cloud Security CNAPP — KSPM / CSPM	For cloud environments, monitors network security group (NSG) policies, VPC configurations, and cloud-native segmentation controls to detect over-permissive network policies that violate segmentation intent.

Gaps & Limitations

CrowdStrike does not provide or configure network segmentation infrastructure (firewalls, VLANs, SDN policies). The platform detects failure modes — lateral movement — but cannot enforce the network control itself. Organisations need dedicated network controls: next-gen firewalls, SDN, cloud-native NSGs. Network-level east-west traffic analysis (NDR) is not currently a native CrowdStrike capability.

Notes for Script Analysis

When mapping these controls into video scripts, the following analytical angles are worth developing:

- Controls 04, 06, 08, 09 — where CrowdStrike is STRONG — are natural product demonstration territory. Real coverage, not marketing fluff.
- Controls 03, 05, 07 — the gap controls — are the honesty moments. CrowdStrike was never designed to be a complete security stack, and naming those gaps plainly is more credible than glossing over them.

- Control 07 (Backups) is worth a specific call-out: Falcon Complete MDR is a world-class detection and response service, but it has no role in testing or validating backups. That boundary matters and should be stated clearly rather than implied.
- Control 08 (Application Control) now includes the Exposure Management software inventory angle. The CrowdStrike OpenClaw blog (Feb 2026) is the on-the-record reference: inventory via Falcon for IT surfaces in the Exposure Management console; NG-SIEM's dashboard provides real-time application activity visibility. This mirrors exactly what NCSC recommends as the 'understand before you enforce' phase.
- Control 09 (Least Privilege) tells the most interesting product evolution story. Falcon Privileged Access (GA April 2025) natively delivers JIT access across hybrid AD and Entra ID — the gap that previously required a standalone PAM tool is now closeable within the Falcon platform itself.
- Control 01 (Patching) highlights the Exposure Management evolution: from 'we found a vuln' to 'here is what to fix first and why' via CTEM and contextual risk prioritisation.
- Control 04 (Centralised Logging) is where NG-SIEM deserves dedicated treatment — it is the connective tissue enabling most other detections across the entire platform.
- Control 02 (MFA) now tells a different story than previous versions. FalconID (GA February 2026) means CrowdStrike natively delivers FIDO2 phishing-resistant MFA — the exact method NCSC recommends as the gold standard. Coverage rating moves from detection-layer to STRONG. The business process verification piece (out-of-band payment/credential change confirmation) remains a gap.
- The MINIMAL controls (03, 05) anchor the vendor ecosystem discussion — no single platform covers everything, and a maturity model lens matters more than any individual product.